

Descripción técnica del estado actual del sistema ERP Geco

El sistema ERP Geco actual opera bajo una arquitectura basada en el patrón MVC (Modelo-Vista-Controlador) implementado con el framework CodeIgniter. La comunicación entre el frontend y el backend se realiza a través de solicitudes HTTP de tipo POST, las cuales no emplean URLs absolutas, sino rutas relativas que siguen una estructura jerárquica interna.

El flujo de acceso típico comienza en el repositorio raíz de CodeIgniter, desde donde se direcciona la solicitud hacia un controlador específico y, posteriormente, al método correspondiente dentro de dicho controlador. Si bien se utilizan métodos POST para la transmisión de datos, no existe una implementación formal de una API RESTful en el sistema, ya que el acceso a los recursos no se realiza mediante una exposición explícita de endpoints con semántica REST (como GET, PUT, DELETE, etc.), sino mediante la invocación directa de métodos de la capa de controladores del MVC.

En resumen, la lógica de negocio y las interacciones con el backend dependen de una arquitectura monolítica orientada a controladores, sin una capa de servicios interoperable mediante estándares REST.

Estructura de Controladores y Métodos

A continuación, se visualiza una tabla con los controladores y los endpoints accesibles desde el frontoend:

Tipo	Descripción
Controller	Administracion
Endpoints	load, save, delete
Controller	Administracion_reportes
Endpoints	repadm0001, repadm0002, repadm0003
Controller	Archivos
Endpoints	downloadXml, saveFile, copyImgEmpRel, subeZip, subeXMLIndividual, downloadATS, eliminaATS, buscaTag, soapToXML, getNombreArchivoRide, subeXLSConciliacion
Controller	Cartera
Endpoints	getCobroXPagarBloque, getTotalFormaPagoBloque, verificaValoresCobro, verificaValoresPago, verificaValoresPagoMultiple, registraCobro, registraPago, registraAnticipoCliente, registraAnticipoProveedor, envioAPagoEnBloque, registraPagoMultiple, anulaAnticipo, reversaPago, reversaCobro, grabaFormaPago, getNroCheque
Controller	Cartera_reportes
Endpoints	repqrt0001, repqrt0002, repqrt0003, repqrt0004, repqrt0005
Controller	Contabilidad
Endpoints	getConceptoByDetCompra, cargaPlanContable, reclasificaCuentas, mayorizar, desMayorizar, activarPeriodo, cambiarPeriodo, registraConciliacion, cierraPeriodo, registraSalDOSIniciales, colocaCodigoContable, validaCodigoContable, eliminaCuenta, anularComprobante, extraerComprasACajaChica, obtUltimaReposicion, reponerCajachica, conciliarBancosVSComprobantes, crearComprobante, reordenarDetalles, generaCierre, reversarCierre, registraRetencion, reversaAnulacion, registrarChequera, copiarComprobante, reversarConciliacion
Controller	Contabilidad_reportes

Endpoints	repctb0001, repctb0002, repctb0003, repctb0004, repctb0005, repctb0006, repctb0007, repctb0008, repctb0009, repctb0010, repctb0011, repctb0012, repctb0013, repctb0014, repctb0015
Controller	Crm
Endpoints	cambiaEmpresaRelacionada, inicializaCaso, grabaCaso, nombreEmpresaRelacionada, sincronizaDatos, retornaNroEstados, porcentajeCumplimiento, agenciasAtendidas, areasAtendidas, casosRecurrentes, enviaPrefectura, genereraPrefectura, reversaPrefectura
Controller	Crm_reportes
Endpoints	repcrm0001, repcrm0002, repcrm0003, repcm0004
Controller	Facturacion
Endpoints	anulaFactura, getTotalFacturaYPorcentaje, registraFactura, registraNotaCredito, generaPDFFactura, generaPDF, obtieneProforma, descargaInventario, agregaProducto
Controller	Facturacion_reportes
Endpoints	repfac0005, repfac0002, repfac0001, fGeneraCabeceraFacturaProforma, fGeneraDetallesFacturaProforma, fGeneraDetalleValorFacturaProforma, fGeneraPieFacturaProforma, repfac0004, repfac0003, repfac0006, repfac0007
Controller	General
Endpoints	grdRead, grdSave, grdDelete, verificaldiomaltinerario, frmSave, frmRead, buscaltem, grabaCampo, getAudit, datosTipo, enviarEmail, obtenerDatosEmail, reenvioEmail, fGenerarDia, getArrayBusqueda, queBusca
Controller	Electronicos
Endpoints	generarXMLSinFirmar
Controller	Inventarios
Endpoints	getKardex
Controller	Inventarios_reportes
Endpoints	repinv0001, repinv0002
Controller	Login
Endpoints	loginPin, inicio, logout, idiomaCombo, cambiaClave, resetClave, cargaldioma
Controller	Modulos
Endpoints	menuModulo
Controller	Personas
Endpoints	obtldReporte, eliminaPersonaCRM
Controller	Personas_reportes
Endpoints	repper0001, repper0002
Controller	Productos
Endpoints	mostrarVista, generarDia, copiarInsumo, obtDescripcionItinerario, revisaldProductoDuplicado, revisaldPrecioDuplicado, grabaDatosItinerario
Controller	Productos_reportes
Endpoints	repprd0001, repprd0002
Controller	Proveedores
Endpoints	getTotalCompraYPorcentaje, registraCompra, generaPDF, cargaCompra, anulaCompra, getFechasXPeriodo, setPorcentajeTamano, registraKardex
Controller	Proveedores_reportes

Endpoints	repprv0001, repprv0002
Controller	Reservas
Endpoints	grabaProductoReservado, eliminaProductoReservado, busquedaCabeceraPrfResFac, busquedaDetallePrfResFac, colocaFechasPax, subeArchivoPax, asignaPaxXInsumo, asignaAllInsumos, buscaInsumos, filtraInsumosXProveedor, asignaProveedor, datosProductoXReservar, datosTipoPrecioXProductoXReservar, datosFechas, buscarReservas, confirmaCorreoProveedor, eliminaDetalleValor, getColumnasOrdenServicio, llenaClasificadores, getProveedoresOrdenServicio, regeneraItinerario, regeneraComponentes, colocaFechaMaxPago, eliminaImpuestos, asignaBloque, colocaNroPaxEnInsumo, importaResFacPfr, copiaTextosElInsumos, getValorDescuento, aplicaDescuento, actualizaejecutado, obtIdCliente, generaCotizador, grabaFilaCotizador, obtDatosInsumo, eliminaInsumo, fechasReserva, cierraReserva, estadoReserva, cambiaDetalleValorXInsumo, apareceProveedor, grabaCheck, procesaRecursoOT, copiaDiaUno, obtenerItinerario, revisaIntercambio, intercambiarDias, limpiarTexto, grabaLugarVuelo, buscaIdDetalle, pagarItemTesoreria, eliminarRegistrosNCVacios, obtenerUnidadPreferida, grabaObservacionFacturacion, grabaProveedorCuadroVentas
Controller	Reservas_reportes
Endpoints	repres0016, repres0019, repres0017, repres0050, repres0009, repres0032, repres0033, repres0043, repres0045, repres0049, repres0001, repres0002, repres0003, repres0004, repres0008, repres0051, repres0054, repres0012, repres0013, repres0020, repres0018, repres0028, repres0029, repres0030, repres0027, repres0052, repres0056, repres0057, repres0058, repres0023, repres0022, repres0015, repres0007, repres0010, repres0026, repres0031, repres0005, repres0011, repres0014, repres0024, repres0025, repres0021, repres0037, repres0038, repchtres0038, repres0042, repres0047, repchtres0047, repres0035
Controller	Restaurante
Endpoints	getCajaDiaria, getMesas, getTiposPlatos, getPlatos, generaMesa, verificaComanda, agregaProducto, generaPrefacturaXComanda, getTotalPorcentajeFormaPagoRst, generaPrefacturaXDetalles, setEstadoCocina, cerrarCajaDiaria, cambiarMesa, unirMesas, generaFactura
Controller	Restaurante_reportes
Endpoints	reprst0008, reprst0001, reprst0002, reprst0003, reprst0004, reprst0005, reprst0006, reprst0007
Controller	Seguridades
Endpoints	generarIdUsuario, getBotones, getBotonesApp, getAccesoCols, resetPassword, grantMenu, revokeMenu
Controller	Seguridades_reportes
Endpoints	repseg0001, repseg0002
Controller	Appservice
Endpoints	login_get, validatoken_post, casos_get, cambiaestado_post, agencias_get, areas_get, tipo_caso_get, caso_recurrente_get
Controller	Externo
Endpoints	connect, getToken, saveTrip, publishTrip
Controller	Facturacion
Endpoints	facturas_get, clientes_get

Controller	Practica
Endpoints	login_post, validatoken_post, creausuario_post, productos_get, grabaproducto_post, subeimagen_post, auth_post
Controller	Servicios
Endpoints	login_get, casos_get, empresas_get, botones_get, aprobar_post, motivos_get, noaplica_post, tiporelacion_get, circulo_get, guardacirculo_post, borracirculo_get, relacionado_get, fichamedica_get, afeccion_get, buscarazon_get, guardaingreso_post, actualizaingreso_post, protocolo_get, estadistica_get, positivossospechosos_get, solicitudedicion_get
Controller	Tareas
Endpoints	envioOffline, bddBckup, cierreAutomaticoCasos, unaBase, mailTimeLimit, akteBckup, revisarReservaSinEstado, ejecutaComando, revisaDiferencia, arreglaFechaInicio

Versiones de las herramientas usadas

Las versiones de las herramientas usadas al momento son las siguientes:

Frontend:

- Sencha Framework Ext Js 7.3

Backend:

- PHP 7.4
- CodeIgniter 3.1

Motor de base de datos:

- MariaDB Server 10.11.17

Resumen de hallazgos de vulnerabilidades por componente

Componente	Versión	Hallazgos principales	Riesgo general
Sencha Ext JS	7.3	Sin vulnerabilidades recientes.	BAJO
PHP	7.4	Múltiples vulnerabilidades críticas y de alta gravedad.	CRÍTICO
CodeIgniter	3.1	Vulnerabilidad CSRF confirmada; múltiples reportes de SQLi en disputa.	ALTO
MariaDB	10.11.17	Vulnerabilidades de DoS y Path Traversal	MEDIO

Análisis Detallado

Frontend: Sencha Ext JS 7.3 - Riesgo Bajo

No se han encontrado vulnerabilidades publicadas para las versiones recientes de Ext JS. Los últimos CVE datan de versiones muy antiguas (anteriores a la 6.6).

Recomendación: Aunque el riesgo es bajo, mantén las buenas prácticas de sanitización de salida para prevenir XSS, ya que el framework por sí mismo no incluye protecciones automáticas.

Backend: PHP 7.4 - Riesgo Crítico

Este es tu punto más crítico. PHP 7.4 alcanzó su fin de vida útil (End of Life) el 28 de noviembre de 2022, lo que significa que ya no recibe parches de seguridad oficiales. Los reportes de vulnerabilidades lo confirman:

Múltiples vulnerabilidades (2024-2026): Se han descubierto decenas de fallos después de su fin de vida, incluyendo ejecución remota de código, omisión de configuración, inyección de cabeceras HTTP y denegación de servicio.

CVE recientes:

CVE-2024-8927: Permite omitir la directiva de seguridad `cgi.force_redirect`.

CVE-2025-14178: Permite la ejecución de código arbitrario.

Backend: CodeIgniter 3.1 - Riesgo Alto

Aunque la versión es "3.1" (probablemente 3.1.x), los análisis se centran en la versión específica 3.1.13, que es la más relevante para tu caso.

Vulnerabilidad Confirmada:

CVE-2024-41344 (CSRF - Cross-Site Request Forgery): Un atacante podría cambiar la contraseña de un usuario administrador.

CWE-352: Debilidad de validación insuficiente en peticiones cruzadas.

Vulnerabilidades en Disputa (Críticas si son ciertas):

Existen múltiples reportes de SQL Injection en el Query Builder de CodeIgniter 3.1.13 (CVE-2022-40824 a CVE-2022-40830), con una severidad base de 9.8 (Crítica).

IMPORTANTE: Estas vulnerabilidades han sido disputadas por terceros, incluyendo al equipo de CodeIgniter. Sin embargo, deben ser evaluarlas en persona, especialmente si el código utiliza las funciones mencionadas (ej. `where()`, `or_like()`, etc.).

Base de Datos: MariaDB 10.11.17 - Riesgo Medio

Tu versión (10.11.17) es de la rama 10.11, que es una rama de soporte a largo plazo (LTS).

Vulnerabilidades Encontradas:

CVE-2023-52970 (Denegación de Servicio): Un usuario con privilegios altos podría causar la caída del servidor.

CWE-1038: Optimizaciones automáticas inseguras.

CVE-2025-13699 (Path Traversal): Un atacante podría ejecutar código arbitrario explotando una ruta en `mariadb-dump`.

CWE-22: Limitación incorrecta de nombres de ruta.